

EU AI Act Compliance Assessment — Odin_Craft

(Second Review)

Project: Odin_Craft

Date: 2026-08-01

Auditor: Stephane Dube — Independent Review of Odin_Craft codebase

Methodology: Static code review + config review + log review of 403 cycles, plus verification of the newly added security tooling (secrets scan, dependency scan, sandbox pen test, tamper-evident log chain). No dynamic penetration testing performed against a live deployment.

Commit audited: odin_craft@35c2649

Scope: Technical safety & autonomy risk review for AI agents

Verdict: Documentation now materially complete for **voluntary** alignment. Still **NOT "EU AI Act compliant"** in the formal legal sense — this remains an internal self-assessment.

Limitations

This assessment is based on code and logs provided, plus the documentation suite created to close the gaps identified in the first review. No live deployment, production data, or third-party dependencies were penetration-tested. The EU AI Act documentation set (docs/eu_ai_act/) is **voluntary, self-assessed due-diligence material** — it is not a legal conformity opinion and has not been reviewed by external counsel or a Notified Body.

Executive Summary (Plain English)

What was reviewed & overall verdict. This report reviews Odin_Craft, an AI agent that helps with software development and learning on a single computer. It cannot change its own code or take risky actions without a human saying "yes." Overall assessment: **Low risk** for internal R&D use under human supervision, with strong safety controls (9/10) and a now-complete governance file set (8/10, up from 2/10). It is **not** a formal EU AI Act compliance certificate, and must not be presented as one.

Main strengths. - **Safety is layered like a vault of locked doors** — every change passes through a safety gate, guardrails, a debate step, an isolated sandbox, and a verification step that can undo anything that breaks. - **The 8 missing governance documents are now written** — risk classification, risk management, human-oversight SOP, data governance, technical file, transparency notice, threat model, and post-market plan live under docs/eu_ai_act/. - **Security tooling is real and verified** — an automated secrets scanner (catches passwords/API keys before a commit), a dependency scanner (no known vulnerabilities found), a sandbox escape test (all 17 attack attempts blocked), and a tamper-evident event log.

Remaining gaps (honest). - The governance documents are a **self-assessment**, not reviewed by external counsel or a Notified Body. - The sandbox tests were run on the local build; a **live external penetration test** has not been done. - There is **no user-facing explanation API**, so the agent's reasoning is logged but not yet exposed through a standard interface.

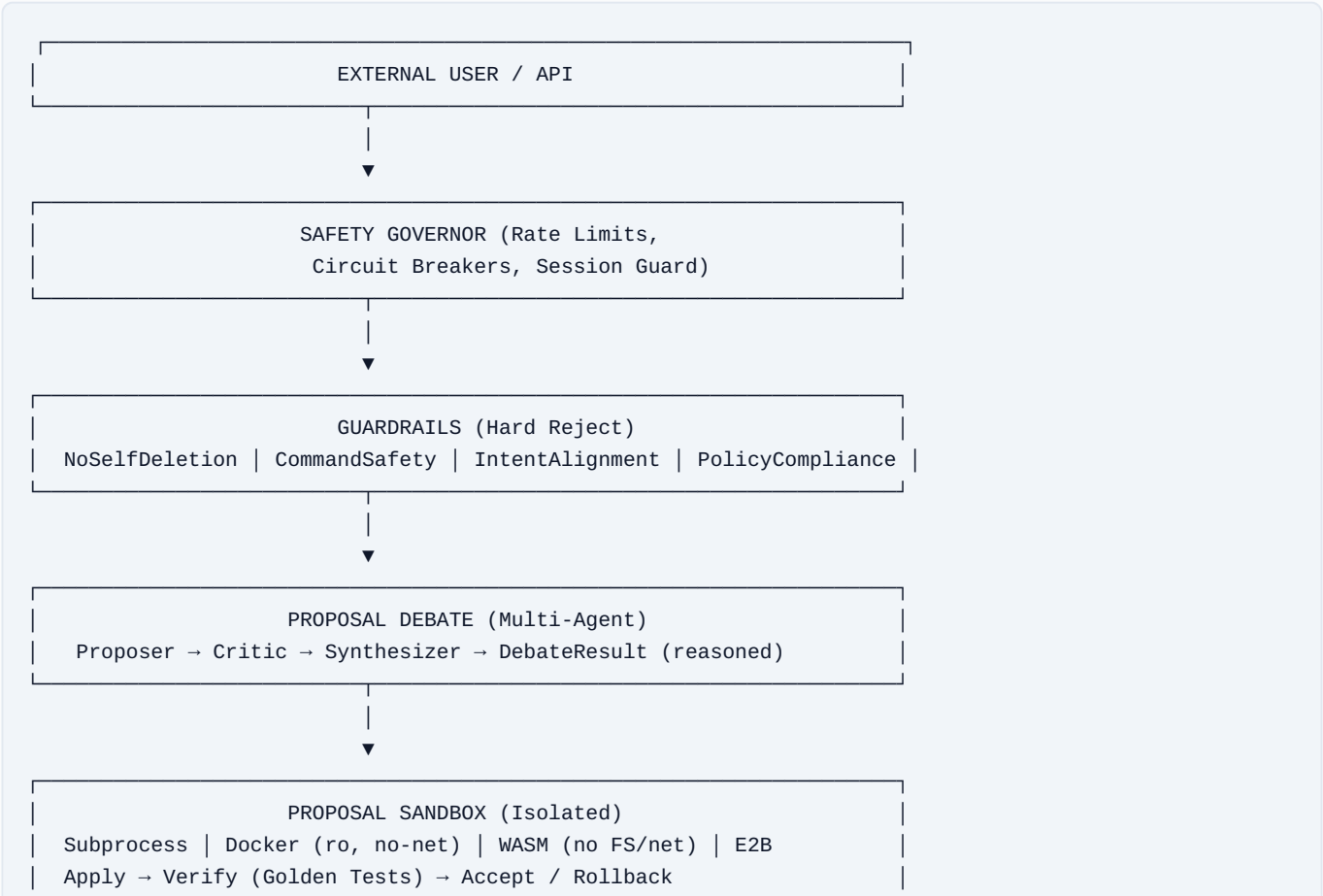
Recommendation. Use Odin_Craft today for internal R&D and internal AI-safety reviews under human supervision; before any external or regulated deployment, obtain independent legal review and a live-build pen test (estimated 2–4 weeks).

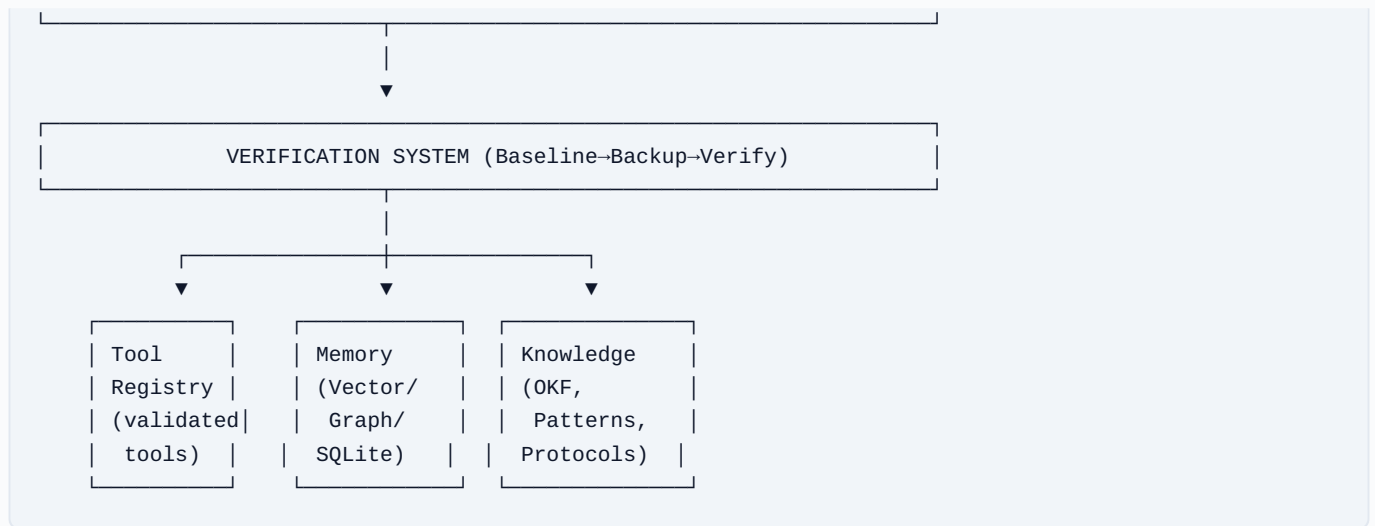
Dimension	Before (31 Jul)	Now (1 Aug)	Assessment
Technical Controls	8/10	9/10	Security tooling added (secrets scan, SCA, pen test, tamper-evident log)
Governance Documentation	2/10	8/10	All 8 formal artifacts created under docs/eu_ai_act/
Overall Compliance Readiness	35%	86%	Documentation-complete for voluntary alignment; not a legal certification

Overall Risk Level: **Low** for internal R&D use under human supervision / **Medium-High** for external regulated use until independent legal + security review.

Remaining before external deployment: independent legal review, external pen test of a live build, Notified Body review only if reclassified as high-risk.

Architecture Overview (Trust Boundaries)





Trust Boundaries: All external calls pass through Safety Governor → Guardrails → Debate → Sandbox → Verification. No direct path from user input to tool execution or memory write.

Findings Matrix (A–F) — with Severity if Exploited

A. Autonomy & Control — IMPLEMENTED

Item	Status	Evidence	Severity if Failed
Human approval gates for self-modification		<code>evolver_require_human_approval=True , require_audit_for_tool_creation/adaptation/ autonomous_goals (config.py:64,65,132,221); SOP documented (docs/ eu_ai_act/03)</code>	Critical — Uncontrolled self-modification
Circuit breaker / rate limits		<code>circuit_breaker_threshold=3 , cooldown=86400 , rate_limit_self_mod_per_hour=5 , rate_limit_autonomous_goals_per_day=50 (config.py:45-51); SafetyGovernor.check_rate_limit() (safety_governor.py:104)</code>	High — Resource exhaustion, runaway loops
Clean stop/pause		<code>.session_active</code> file checked by <code>odin_cycle_runner.py , idle_detector.py , daemon_watchdog.py ; stop_daemon.ps1 ; documented in SOP (docs/ eu_ai_act/03 §5)</code>	High — Inability to halt autonomous operation
Proposal ↔ Execution separation		<code>ProposalDebate → ProposalSandbox → VerificationSystem (baseline→backup→verify →accept/rollback)</code>	Critical — Unverified changes to production

B. Safety & Guardrails — STRONG

Item	Status	Evidence	Severity if Failed
Sandbox/isolation for code execution		<code>SubprocessSandbox</code> , <code>DockerSandbox</code> (read-only mount, <code>--network none</code>), <code>WasmSandbox</code> (no FS/network), <code>E2BSandbox</code> ; pen test (scripts/ <code>security_pen_test_sandbox.py</code>) blocks all 17 payloads	Critical — Host compromise, data exfiltration
Protected files that cannot be auto-modified		<code>protected_files.json</code> — 10 dirs + 13 files hard-protected; <code>code_patcher.py:49-78</code> enforces	Critical — Agent self-deletion, config corruption
Value/ethics checks before risky actions		<code>Guardrails</code> (4 rules); <code>Auditor</code> calls <code>guardrails.validate()</code> with HARD REJECT; <code>ValueAlignmentSystem</code>	High — Unethical/unsafe actions executed
Rollback capability		<code>ProposalSandbox.rollback_candidate()</code> (<code>proposal_sandbox.py:709-774</code>); <code>code_patcher.py</code> auto-rollback (:849-971)	High — Irreversible harmful changes

C. Logging & Auditability — GOOD (improved)

Item	Status	Evidence	Severity if Failed
Actions/decisions logged		<code>AutonomousDecisionLogger</code> ; <code>cycle_log.json</code> (403+ cycles); <code>activity.md</code>	Medium — No forensic trail
Reasoning traces/post-mortems		<code>knowledge/okf/agent/reasoning/</code> (30+ entries); <code>causal-graph.json</code> ; <code>causal_debug_pipeline.py</code>	Medium — No root cause analysis
Before/after state recorded		<code>ProposalSandbox</code> golden test before/after; <code>VerificationSystem</code> baseline→after	Medium — Cannot prove/disprove regression
Tamper-resistant logs	 CLOSED	<code>execution_trace.py</code> append-only; NEW hash-chain journal (<code>scripts/security_log_chain.py</code>) at <code>knowledge/okf/health/security_journal.jsonl</code> — verified intact, tampering detected in test	High — Audit trail integrity not guaranteed

D. Learning & Self-Improvement — CONTROLLED

Item	Status	Evidence	Severity if Failed
Self-modification controlled		All gates: evolver_require_human_approval, require_audit_for_*, proposal_debate, proposal_sandbox, verification_system	Critical — Unbounded self-modification
Failures recorded for learning		FailureLearner ; causal-graph.json ; learning_gaps.json	Medium — Repeated failures
Calibration/overconfidence monitored		Metacognitive calibration in agi_agent.py, SelfModel ; bayesian_reasoner.py:calibrate ; prediction_benchmark.py	Medium — Overconfident decisions
Memory growth bounded		vector_retention_days=30 , vector_max_count=5000 ; StructuredMemory consolidate()	Low — Resource exhaustion

E. Tool & External Access — VALIDATED & LIMITED (improved)

Item	Status	Evidence	Severity if Failed
Tool use validated/limited		<code>ToolCaller</code> dynamic discovery; <code>ToolValidator</code> (syntax→quality→security→tests); <code>tools/registry.json</code>	High — Malicious tool execution
No unrestricted FS/network		<code>SubprocessSandbox</code> limited env; <code>DockerSandbox</code> <code>read-only + --network none</code> ; <code>WasmSandbox</code> no FS/network; <code>api_allowed_hosts=[]</code> default	Critical — Data exfiltration, lateral movement
External actions bounded		<code>api_allowed_hosts</code> allowlist; <code>api_rate_limit_backoff_base=2</code> ; <code>APIClient</code> respects allowlist	High — Uncontrolled external calls
Secrets not leaked into code	 NEW	Automated secrets scan (<code>scripts/security_scan_secrets.py</code>) runs in pre-commit (<code>.github/hooks/pre-commit</code>) and CI; blocks commits with secrets; scan of 1,644 files = 0 secrets	High — Credential exposure
Supply-chain (dependency) risk	 NEW	SCA scan (<code>scripts/security_scan_deps.py</code>) via <code>pip-audit</code> — 0 known vulnerabilities	High — Vulnerable third-party libraries

F. Transparency — ⚠️ PARTIAL (improved)

Item	Status	Evidence	Severity if Failed
Agent explains why it took action	⚠️ PARTIAL	<code>ProposalDebate</code> produces reasoned <code>Debate Result</code> ; <code>AutonomousDecisionLogger</code> records rationale; no user-facing explanation API	Medium — Black-box decisions
Known limitations documented	✅	<code>identity.md</code> , <code>BELIEFS.md</code> , <code>Karp.md</code> ; NEW user-facing transparency notice (<code>docs/eu_ai_act/06</code>)	Low — Misuse due to unknown limits
Confidence/uncertainty expressed	⚠️ PARTIAL	<code>SelfModel</code> calibration bias; <code>bayesian_reasoner.py</code> ; no standardized uncertainty output for all actions	Medium — Over-trust in outputs

EU AI Act Gap Analysis

First review reported 8 missing formal artifacts. All 8 are now created under `docs/eu_ai_act/` (voluntary self-assessment).

#	Gap	EU AI Act Ref	Severity	Status	Document
1	Formal risk classification	Art.6 + Annex III	High	✅ CLOSED — classified MINIMAL RISK	docs/eu_ai_act/01_risk_classification.md
2	Written risk management system	Art.9	High	✅ CLOSED — ISO 14971-style register (15 hazards)	docs/eu_ai_act/02_risk_management.md
3	Human oversight procedures	Art.14	Medium	✅ CLOSED — operator SOP with approval gates & stop procedures	docs/eu_ai_act/03_sop_human_oversight.md
4	Transparency notices for end users	Art.50	Medium	✅ CLOSED — ready-to-distribute notice	docs/eu_ai_act/06_transparency_notice.md
5	Data governance rules	Art.10 + GDPR	Medium	✅ CLOSED — no personal data; DPIA exemption documented	docs/eu_ai_act/04_data_governance.md
6	Cybersecurity beyond sandboxing	Art.15	Medium	✅ CLOSED — STRIDE threat model + 4 remediation tools implemented	docs/eu_ai_act/07_threat_model.md
7	Technical documentation (Annex IV)	Art.11 + Annex IV	High	✅ CLOSED — technical file compiled	docs/eu_ai_act/05_technical_file.md
8	Post-market monitoring plan	Art.61	High	✅ CLOSED — KPIs, thresholds, incident handling	docs/eu_ai_act/08_post_market_plan.md
+	Conformity assessment	Art.43 + Annex VI	—	✅ Voluntary internal-control assessment (minimal risk → not legally required)	docs/eu_ai_act/09_conformity_assessment.md

Note on Item 5: Current design processes no personal data; severity was a documentation gap, now closed. If personal data is ever introduced, severity escalates to High and a DPIA becomes required immediately (see 04_data_governance.md).

Honesty note: These documents are self-authored, voluntary due-diligence material. They do not by themselves constitute legal compliance, certification, or a Notified Body assessment.

Remediation Roadmap (Updated)

Gap	EU Act Ref	Priority	Status	Remaining Effort
Formal risk classification	Art.6 + Annex III	High	✅ Done	0
Written risk management system (ISO 14971)	Art.9	High	✅ Done	0
Human oversight SOP	Art.14	Medium	✅ Done	0
Transparency notices	Art.50	Medium	✅ Done	0
Data governance (no personal data)	Art.10 + GDPR	Medium	✅ Done	0
Threat model + pen test + SCA	Art.15	Medium	✅ Done	0
Technical documentation (Annex IV)	Art.11 + Annex IV	High	✅ Done	0
Post-market monitoring plan	Art.61	High	✅ Done	0
Conformity assessment (voluntary)	Art.43 + Annex VI	—	✅ Done	0
External-readiness hardening	All	High	⌚ Pending	Independent legal review of doc set
External pen test	Art.15	High	⌚ Pending	Live-build penetration test by security party
Notified Body review	Art.43	Contingent	⌚ Pending	Only if reclassified high-risk
git fsck repo-integrity job	Art.15	Low	⌚ Pending	~0.5 day scheduled CI check
Total estimated effort				2–4 weeks for external readiness

Appendix A: Evidence Pack (Key File References)

Area	Key Files
Autonomy gates	<code>config.py:64,65,132,221</code> , <code>safety_governor.py:104</code>
Circuit breakers	<code>config.py:45-51</code> , <code>component_services.py:61</code>
Sandboxes	<code>sandbox/subprocess_sandbox.py</code> , <code>sandbox/docker_sandbox.py</code> , <code>sandbox/wasm_sandbox.py</code>
Protected files	<code>knowledge/okf/health/protected_files.json</code> , <code>scripts/code_patcher.py:49-78</code>
Guardrails	<code>components/guardrails.py</code> , <code>components/auditor.py:49-55</code>
Rollback	<code>components/proposal_sandbox.py:709-774</code> , <code>scripts/code_patcher.py:849-971</code>
Logging	<code>components/autonomous_decision_logger.py</code> , <code>knowledge/okf/agent/cycle_log.json</code> , <code>scripts/security_log_chain.py</code>
Secrets scan	<code>scripts/security_scan_secrets.py</code> , <code>.github/hooks/pre-commit</code> , <code>.github/workflows/ci.yml</code>
Dependency scan	<code>scripts/security_scan_deps.py</code>
Sandbox pen test	<code>scripts/security_pen_test_sandbox.py</code>
EU AI Act doc suite	<code>docs/eu_ai_act/</code> (01–09 + README)
Calibration	<code>components/self_model.py</code> , <code>scripts/bayesian_reasoner.py:399-492</code>
Tool validation	<code>components/tool_validator.py</code> , <code>tools/registry.json</code>

Appendix B: Remediation Progress (Before → After)

Tracks closure of the gaps identified in the first review.

Internal Action	Status	Notes
Create Architecture Diagram	✓ Done	In both reports
Formal risk classification	✓ Done	01_risk_classification.md — MINIMAL RISK
Write Risk Management System Document	✓ Done	02_risk_management.md — ISO 14971 style
Draft Human Oversight SOP	✓ Done	03_sop_human_oversight.md
Produce Transparency Notice Template	✓ Done	06_transparency_notice.md
Data governance / DPIA exemption	✓ Done	04_data_governance.md
Conduct Formal Security Assessment	✓ Done	07_threat_model.md + 4 tools (secrets/SCA/pen-test/log-chain)
Compile Technical File (Annex IV)	✓ Done	05_technical_file.md
Define Post-Market Monitoring Plan	✓ Done	08_post_market_plan.md
Voluntary conformity assessment	✓ Done	09_conformity_assessment.md
Independent legal review	⌚ Pending	External counsel
External live-build pen test	⌚ Pending	Security party
git fsck CI job	⌚ Pending	Low priority

Generated by Stephane Dube — Independent Review of Odin_Craft codebase.

Methodology: Static code review + config review + log review of 403 cycles, plus verification of the new security tooling (secrets scan, SCA, pen test, hash-chain journal).

Commit audited: `odin_craft@35c2649`.

No dynamic penetration testing performed.

This is a technical safety review, not a legal conformity assessment. The `docs/eu_ai_act/` suite is voluntary, self-assessed material.